PROJECT STEPH / LOKI

Conversation Summary & Planned Changes

Purpose
Capture the project direction and repository improvements discussed: turning the existing application into a secure, read-only AI-assisted Wintel troubleshooting platform that uses ServiceNow, approved knowledge, AWS, and Terraform.

Item	Summary
Repository	https://github.com/Juupppiiii/Project-STEPH
Project naming	Project STEPH / Project LOKI (names used in the discussion)
Environment	Hybrid Windows Server / Active Directory; Microsoft Entra ID; ServiceNow; AWS and Terraform.
MVP boundary	**Read-only.** No automatic remediation, arbitrary command execution, or production changes.

Executive summary

The recommendation is to evolve the current repository rather than rebuild it. Retain the React/FastAPI interface, Entra sign-in, ServiceNow read-only connector, procedure and knowledge components, simulation-only action boundary, worker/workflow architecture, PostgreSQL option, and Terraform foundation where they remain fit for purpose.

The planned sequence is: verify the current code and infrastructure; fix identity, authorization, audit, and workflow reliability; improve read-only ticket investigation and evidence-backed recommendations; add a fixed catalog of read-only Windows diagnostics; then harden and pilot the AWS deployment.

> **Core safety principle: AI can summarize evidence and suggest an approved diagnostic. Server-side policy—not the model—must decide whether it is allowed. Keep production remediation disabled in the MVP.**

1. Existing repository foundation

The following reflects the repository documentation and prior discussion. It is a planning baseline, not confirmation that every component has been re-tested against the latest commit.

Area	Existing foundation described	Planned treatment
UI / API	React UI and FastAPI under overlay/.	Reuse; improve investigation UX, schemas, error handling, and audit visibility.
Identity	Entra OIDC/session handling in overlay/auth.py.	Use validated server-side claims; never trust client-supplied actor identity headers.
ServiceNow	Read-only polling/connector described in overlay/live.py.	Dedicated least-privilege OAuth identity and separate employee ticket authorization.
Knowledge	system2/ procedure engine; knowledge/ artifacts; src/ offline mining pipeline.	Improve retrieval, source citations, metadata, freshness, and procedure coverage.
Action boundary	overlay/action_gateway.py described as default-deny and simulation-only.	Preserve simulation; introduce a separate read-only diagnostics boundary.
Workflow / data	SQS, Step Functions, worker files, SQLite local store, PostgreSQL production store.	Add idempotency, retries, leases, recovery, durable state transitions, and DLQ monitoring.
Infrastructure	Terraform under infrastructure/ for ECS, ALB, database, queues, IAM, and logs per documentation.	Audit state/resource ownership and resolve any Terraform/CDK documentation overlap.

Before making changes

- Confirm current branch and commit, inspect actual call paths, and run the existing tests.
- Inspect whether Terraform and legacy CDK/deployment definitions overlap; avoid multiple IaC owners for the same AWS resources.
- Check Terraform state, backend/locking, existing AWS resources, networking, and ownership before import, replacement, or apply.
- Keep credentials and sensitive incident content out of source control and logs.

2. Target architecture

Layer	Target	Guardrail
Access	Internal React + FastAPI app behind internal ALB; Entra SSO.	Authorization enforced on every protected server route.
Ticket context	ServiceNow adapter using a dedicated OAuth client.	Integration credentials do not replace per-employee ticket authorization.
Reasoning	Retrieve approved runbooks and resolved incidents; Bedrock may synthesize evidence and next steps.	Cite sources; treat ticket text as untrusted data; model output cannot grant permission.
Diagnostics	Fixed catalog of read-only operations; consider SSM for approved managed nodes.	No arbitrary PowerShell; validate operation, target, parameters, timeout, and output size.
Orchestration	API → workflow/SQS → worker → approved connector → evidence/result store.	Idempotency, bounded retries, recovery, explicit states, and DLQ alerts.
Security / data	Aurora PostgreSQL, Secrets Manager, KMS, CloudWatch, private networking, least-privilege roles.	Separate API, worker, ServiceNow, and diagnostic identities; redact sensitive data.

Hybrid environment considerations

Validate connectivity, DNS, routes, firewall rules, and Systems Manager requirements before using SSM for hybrid nodes. Do not expose WinRM/RDP publicly or grant broad Domain Admin access. AD health checks should use a designated management path and a tightly scoped, read-only delegated identity.

3. Planned engineering workstreams

A. Identity, authorization, and audit

- Use the authenticated Entra identity as the actor; reject or ignore X-Actor and similar client-supplied identity headers.
- Define server-side roles such as Viewer, Investigator, and Admin, and enforce access for each ticket, evidence item, and diagnostic operation.
- Separate ServiceNow integration credentials from the employee session and document the integration account's read-only permissions.
- Audit requester, ticket reference, authorization decision, diagnostic ID, target, timestamps, and result; redact secrets.

B. ServiceNow investigation pipeline

- Normalize ticket fields such as ID, category, priority, description, assignment group, state, related CI, and timestamps.
- Enforce ticket-level authorization; add bounded pagination, timeouts, rate limits, and safe error handling.
- Present a timeline separating ticket facts, knowledge evidence, diagnostic results, limitations, and recommended next steps.

C. Evidence-backed knowledge and AI

- Index approved runbooks, handbooks, and sanitized resolved incidents with source, owner, version, and review date.
- Retrieve evidence before generating a summary; label assumptions, gaps, and uncertainty.
- Cite sources for material recommendations and prevent ticket text or retrieved content from acting as system instructions.
- Evaluate retrieval and procedure matching against a labeled set of representative tickets.

D. Read-only diagnostic gateway

- Create fixed operation IDs with reviewed implementations and strict parameter validation.
- Initial candidates: DNS lookup, TCP connectivity to approved host/port, Windows service status, disk free space, bounded event-log queries, and selected read-only AD health checks.
- Allowlist targets, ports, operations, timeouts, output limits, and identities; deny unknown operations by default.
- Keep simulation separate. No arbitrary scripts, account changes, service restarts, Group Policy edits, or automatic remediation.

E. Workflow and persistence reliability

- Define explicit states such as requested, authorized, queued, running, succeeded, failed, cancelled, and expired.
- Add idempotency keys, atomic transitions, worker lease/claim recovery, and safe retry semantics.
- Configure queue visibility timeouts, DLQ handling, alarms, and controlled replay procedures.
- Test concurrent requests, duplicate messages, worker crashes, timeouts, and cancellation.

F. Terraform and operations

- Review existing state and AWS ownership before importing, renaming, replacing, or deleting resources.
- Separate dev/staging/prod configuration and state; protect remote state and use locking/versioning supported by the backend.
- Review private networking, security groups, ALB exposure, task roles, database access, KMS, secrets, and log retention.
- Pin versions, review plans, run IaC checks, and document deployment, rollback, and drift-response procedures.

G. Testing and observability

- Test authorization, risk decisions, parameter bounds, prompt-injection resistance, and redaction.
- Add integration and failure-injection tests for ServiceNow, PostgreSQL, queue retries, workflow recovery, and denied operations.
- Track investigation duration, allow/deny decisions, failures, queue age, retries, and evidence coverage.
- Alert on API errors, worker failures, DLQ depth, stuck jobs, authorization denials, and unusual diagnostic volume.

4. Repository change map

Path	Planned change	Priority
overlay/auth.py	Validate Entra claims, derive actor server-side, secure sessions, map roles.	P0
overlay/api.py	Route authorization, request validation, limits, safe errors, audit hooks.	P0
overlay/service.py	Orchestrate authorization, evidence retrieval, policy checks, and workflow states.	P0/P1
overlay/live.py	Harden read-only ServiceNow adapter, OAuth, pagination, timeouts, field minimization.	P1
overlay/planner.py / risk.py	Evidence-backed plans, explicit uncertainty, default-deny operation selection.	P1
overlay/action_gateway.py	Keep simulation-only; do not quietly enable production write execution.	P0
overlay/connectors.py	Typed contracts for read-only diagnostic requests and responses.	P1
overlay/worker*.py	Idempotency, leases, recovery, bounded retries, cancellation, durable results.	P0/P1
overlay/postgres_store.py	Atomic transitions, durable jobs/evidence, indexes, concurrency tests.	P0/P1
system2/procedures.json	Improve Wintel procedures, matching coverage, validation, and fixtures.	P1
knowledge/ and src/	Curate sources, add metadata, evaluate retrieval and matching.	P1
infrastructure/ Terraform	Review ownership/state; refine IAM, network, secrets, logs, diagnostic permissions, environments.	P0/P2
tests/ and CI	Security, integration, failure-injection, and IaC validation.	P0 onward

Note: paths are likely touchpoints based on documented structure. Confirm exact filenames and current implementation before editing.

5. Recommended implementation sequence

Phase	Deliverables	Exit criteria
0 — Verify baseline	Check commit, run tests, map API/service/store/worker, inspect IaC state and risks.	Reproducible baseline; no unreviewed infrastructure changes.
1 — Security and durability	Fix actor trust, RBAC/ticket scope, secrets, audit, idempotency, and recovery.	Authorization tests pass; duplicate/crashed jobs recover safely.
2 — Investigation workspace	Reliable read-only ServiceNow retrieval, cited knowledge, evidence timeline.	Selected tickets have traceable facts and next steps without writes.
3 — Read-only diagnostics	Operation catalog, target allowlist, constrained adapter, hybrid connectivity checks.	Only approved operations run; invalid operations are denied and audited.
4 — AWS/Terraform hardening	State/environment cleanup, least privilege, private networking, alarms, recovery runbook.	Reviewed plan, tested alerts, no duplicate IaC ownership.
5 — Controlled pilot	Small set of ticket categories, operator feedback, evaluation set, disable/rollback procedure.	Security gate passed; measured usefulness; no automatic remediation.

6. Proposed pilot measures

Measure	Proposed goal	Verification
Authorization	All protected routes enforce server-side authorization; unauthorized diagnostic requests denied.	Automated positive/negative tests and audit review.
Evidence traceability	Every material recommendation links to ticket facts, approved knowledge, or diagnostic output.	Sample review of pilot investigations.
Diagnostic safety	No arbitrary command execution; only approved operation IDs and targets run.	Negative tests, audit records, and code review.
Reliability	Duplicate delivery/crashes do not silently lose work or duplicate side effects.	Failure-injection and recovery tests.

Measure	Proposed goal	Verification
Usefulness	After baseline, test a hypothesis of ~20% lower investigation time and ≥70% operator acceptance.	Compare equivalent ticket categories and report sample size.
Diagnostic quality	Pilot hypothesis of ≥95% validated result accuracy on a labeled test set.	Wintel reviewer validation; model confidence is not ground truth.

These are proposed targets, not measured results or guarantees. Establish a baseline before deciding whether the targets are appropriate.

7. Non-negotiable guardrails

- **Read-only MVP:** no automatic remediation, production writes, account/group changes, service restarts, GPO changes, or ServiceNow ticket updates.
- **No arbitrary commands:** never pass model-generated shell or PowerShell text directly to a host; use fixed reviewed operations.
- **Least privilege:** separate API, worker, ServiceNow, and diagnostic identities; avoid Domain Admin and broad AWS permissions.
- **Ticket-level access:** a shared ServiceNow OAuth client does not prove that the employee can access every ticket.
- **Prompt-injection resistance:** ticket text, logs, emails, runbooks, and retrieved documents are data—not instructions or authorization policy.
- **Secret/data hygiene:** keep secrets out of Git and logs; minimize incident data; define retention and access controls.
- **Infrastructure safety:** inspect Terraform plans and resource ownership; isolate state by environment; avoid accidental replacement/deletion.
- **Human control:** show evidence and proposed next steps; any future remediation remains a separate, explicitly approved phase.

8. MVP definition of done

- An investigator signs in through Entra ID and only sees tickets they are authorized to access.
- The app retrieves approved ServiceNow data and knowledge with traceable citations.
- A predefined read-only diagnostic can run only after identity, operation, target, parameters, and limits are validated.
- The UI separates observed facts, diagnostic results, inferred explanations, and suggestions.
- Workflows survive duplicate messages, crashes, timeouts, and retries without silently losing work.
- Sensitive data is redacted and access/diagnostic outcomes are auditable.
- Terraform state ownership and deployment/rollback steps are documented and reviewed.
- Tests prove unauthorized requests and unapproved operations are denied; no production write path is enabled.

9. Immediate next actions

Order	Action	Expected result
1	Freeze a baseline commit and run the current test suite.	Known-good reference.
2	Trace authentication/actor identity through API → service → worker; test spoofed headers.	Confirm highest-priority identity risks.
3	Inspect transaction boundaries, idempotency, leases, retries, and DLQ behavior.	Reproducible reliability issue list.
4	Review Terraform backend/state and map resources to AWS ownership.	Safe infrastructure change plan.
5	Choose 2–3 Wintel ticket categories and build a sanitized evaluation set.	Bounded MVP scope and measurable baseline.

Reference and scope note

Repository: https://github.com/Juupppiiii/Project-STEPH

This PDF consolidates the project discussion and planned changes; it is not a complete transcript of every message in the chat, a verified code audit, or authorization to apply AWS changes. Verify the latest repository, AWS account, and team policies before implementation.